SPIKA TECH™

NORMA DE PROTECCIÓN FRENTE A SOFTWARE MALICIOSO

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 MEDIDAS Y PAUTAS DE SEGURIDAD 4
3.1 Antivirus o EDR 5
3.2 Cortafuegos 6
3.3 Protección antimalware, Protección ante el malware, antispam y antiphishing en correos electrónicos y navegación web 6
3.4 Norton 7
3.5 Concienciación y formación del personal 8
3.6 Pautas generales sobre las medidas de seguridad planteadas 8
4 DEFINICIONES 9
5 Referencias 11

1 OBJETIVO

El objeto de la presente norma es describir las directrices y pautas a seguir sobre protección frente a software malicioso como: Gusano, Malware, Phishing, Ransomware, Rootkit, Spyware, Adware, Troyano y/o Virus, que permita la protección de los equipos tecnológicos frente a los ataques de código de malicioso.

2 ALCANCE

Esta norma de seguridad aplica a los siguientes sistemas de SPIKA TECH:

- Aplicaciones de SPIKA TECH.
- Ordenadores portátiles y de sobremesa del personal.
- Dispositivos IoT.

3 MEDIDAS Y PAUTAS DE SEGURIDAD

A continuación, se describen las pautas o medidas de seguridad a tener en cuenta para prevenir el software malicioso en los diferentes vectores de ataque:

- **Antivirus.**
- **Cortafuegos.**
- **Protección ante el malware, antispam y antiphishing en correos electrónicos y navegación web.**
- **Norton**
- **Concienciación y formación del personal.**
- **Pautas generales sobre las medidas de seguridad.**

Estas medidas y pautas de seguridad están constituidas por el conjunto de acciones que se deben realizar para evitar infecciones por malware desde diferentes vectores de ataque, como son: equipos, red interna y/o externa, correos electrónicos, nube, entre otros. Cuando se

mencionan medidas de seguridad, hace referencia a técnicas que detectan y previenen un incidente de seguridad. En este sentido, se implementa un ciclo de protección completa, consistente en (i) Protección/Prevención; (ii) Detección; (iii) Resolución y respuesta y (iv) Adaptación.

3.1 Antivirus o EDR

Con carácter general, los sistemas tendrán instalado un software que evite las infecciones por malware.

En la instalación y mantenimiento del producto, se tendrán en cuenta, además, los siguientes requerimientos:

- El software se instalará en los servidores equipamiento de usuario incluyendo equipos de sobremesa y portátiles.
- El software y su base de datos serán actualizados permanentemente y mantenidos en base a las actualizaciones y recomendaciones proporcionadas por el fabricante y atendiendo a las necesidades del servicio del Ministerio.
- En el caso de que se opte por una solución antivirus, se programará un escaneo específico de los sistemas para la detección de código dañino en equipamiento de usuario de forma periódica.
- El software permitirá una administración centralizada, con acceso restringido al personal que lo requiera para el desarrollo de sus funciones.
- Al arrancar los sistemas, se deberá tener configurado el análisis de las funciones críticas del sistema operativo en prevención de modificaciones no autorizadas. Asimismo, analizará automáticamente los dispositivos extraíbles que se conecten al sistema.
- La instalación del software antimalware será realizada por personal especializado que asegure una adecuada configuración del dispositivo.
- Los informes y alertas de incidencia generados por la consola de la herramienta deberán ser monitorizadas por el Administrador del Sistema notificando en caso de

incidencia a la persona Responsable de la Seguridad, o la persona o equipo en que este delegue.

- Cualquier equipo no corporativo que tenga acceso a cualquier activo de los sistemas de información de la organización, deberá tener instalado y actualizado con algún antivirus.

3.2 Cortafuegos

- Se deberá disponer de al menos un cortafuegos o firewall, diseñado para proteger los sistemas, bloqueando accesos no autorizados y permitiendo solo los que deban ser permitidos.

3.3 Protección antimalware, Protección ante el malware, antispam y antiphishing en correos electrónicos y navegación web

Una de las principales formas de propagación utilizadas por el malware es el correo electrónico. SPIKA TECH debe disponer de un sistema de protección de correos electrónicos que cumpla los siguientes criterios:

- Análisis de todos los correos de entrada y salida de la entidad y bloqueo de aquellos que considere peligrosos.
- Filtrado de correos no deseados (spam) y phishing.
- Se establecerán, entre otras, las siguientes reglas:
    - Por protocolos.
    - De bloqueo de orígenes maliciosos
    - De bloqueo de adjuntos que elimina tipos de ficheros empleados ampliamente por atacantes.
    - De bloqueo de adjuntos con macro.
    - De análisis de enlaces web tanto en cuerpos de mensaje como en adjuntos, que no permite el acceso a las de mala reputación

- De aviso de correos enviados desde dominios creados recientemente.
- De aviso de un número elevado de correos que llegan desde una misma dirección a diferentes destinatarios.

Asimismo, SPIKA TECH debe disponer de un sistema de protección de navegación web, el cual se recomienda que proporcione las siguientes protecciones:

- Proporcionará protección frente a páginas o código malicioso.
- Permitirá filtrado a un conjunto de URLs de direcciones no deseadas incluida en una lista negra a las que se impedirá el acceso desde la red corporativa de la entidad, relacionadas a distintas materias, a modo de ejemplo: abuso de drogas; hacking, asuntos ilegales o poco éticos; discriminación; violencia explícita; grupos extremistas; evasión de proxy; abuso sexual de menores; minería de criptomonedas; material para adultos en general, pornografía; armas; marihuana; sitios maliciosos; phishing; spam URLs, dynamy DNS, ente otras.
- Impedirá la navegación a dominios con mala reputación.
- Permitirá la clasificación por categorías de páginas web, denegando el acceso a aquellas que pudieran suponer un riesgo para la organización, tales como descarga de software, hacking, juego, pornografía y otras.
- El Administrador de Sistema, completará la lista negra de direcciones no permitidas. En su caso, el Responsable de Seguridad, o las personas en las que éste delegue, podrá proponer nuevas y supervisar las existentes, o las personas que este haya designado.
- La herramienta almacenará eventos de seguridad con las conexiones realizadas.

3.4 Norton

Para facilitar el cumplimiento de algunas de las medidas de seguridad señaladas, así como para obtener otros resguardos, SKIPA TECH tiene implementado Norton, a modo de medida de seguridad propiamente tal. Mediante esta herramienta se facilita la visibilidad e interrupción automática de procedimientos de ataque y respuesta acelerada en los puntos de conexión,

identidades, correo electrónico y datos, así como monitorización y seguimiento de incidentes de seguridad, recolección de su tipología, fecha de inicio, métricas, etc. Los servicios proporcionados protegen, entre otros, los siguientes:

- Puntos de conexión: Detecta y protege dispositivos de puntos de conexión y dispositivos de red.

- Recursos: Ofrece administración de vulnerabilidades mediante la visibilidad continua de los recursos, evaluaciones inteligentes basadas en riesgos y herramientas de corrección integradas para abordar vulnerabilidades y configuraciones incorrectas.

- Aplicaciones en la nube: Otorga visibilidad, controla datos y detecta amenazas en todos los servicios y aplicaciones en la nube.

- Correos electrónicos y documentos: Protege frente a amenazas malintencionadas planteadas por mensajes de correo electrónico, vínculos (direcciones URL) y herramientas de colaboración.

3.5 Concienciación y formación del personal

- SPIKA TECH fomentará el desarrollo de las acciones necesarias para concienciar regularmente a las personas acerca de su papel y responsabilidad para que la seguridad del sistema alcance los niveles exigidos. SPIKA TECH fomentará el desarrollo de planes de formación, enfocados y dirigidos al personal, para que reciban sesiones de concienciación en materia de seguridad de la información de manera periódica.

- En particular, el contenido de la formación debe incluir normativa, buenas prácticas, recomendaciones, técnicas y novedades en relación a la protección frente a código malicioso, incluyendo identificación y notificación de incidentes de seguridad relativos a la infección por malware.

3.6 Pautas generales sobre las medidas de seguridad planteadas

En las soluciones planteadas anteriormente, adicionalmente y/o reiterando lo indicado, se deberá:

- Monitorizar la información generada por las soluciones de seguridad implantadas, para ello, existen Cuadros de Mando que permiten conocer el estado de los principales aspectos de seguridad de los equipos, así como su gestión.

- Disponer de mecanismos que impidan que la persona usuaria final detenga o altere el funcionamiento de las soluciones.

- El Administrador del Sistema garantizará en su parte técnica que las soluciones mencionadas estén cubiertas por un acuerdo de soporte y actualización, tanto del software como de la base de datos de detección.

4 DEFINICIONES

Cortafuegos (Firewall): Tecnología que bloquea el tráfico de red que coincide con patrones definidos mediante reglas, limitando o impidiendo completamente la comunicación de ciertas aplicaciones que se ejecutan en los puestos y restringiendo su superficie de exposición.

Fichero de firmas: Es el fichero que contiene los identificadores de los virus que permite al antivirus detectar a los virus.

EPP (Endpoint Protection Platform, antivirus): Categoría de herramientas de seguridad orientadas a proteger los puestos de usuario y servidores del código dañino conocido.

EDR (Endpoint Defense and Response): Nueva categoría de herramientas de seguridad orientada a detectar investigar y resolver actividades sospechosas en puestos de usuario y servidores.

Phishing: Técnica que consiste en el envío de un correo electrónico por parte de un ciberdelincuente simulando ser una entidad legítima, a través del engaño o fraude, con el fin de obtener información sensible o instalación de malware.

SPF: (Sender Policy Framework) Protocolo de autenticación de correo electrónico utilizado para detectar phishing. Ayuda a verificar quién puede enviar o recibir correos electrónicos (por el dominio).

DKIM: (DomainKeys Identified Mail) Protocolo de autenticación de autenticación de correo electrónico utilizado para detectar phishing. Ayuda a garantizar la legitimidad del remitente.

DMARC: (Domain-based Message Authentification Reporting and Conformance) Protocolo de autenticación de correo electrónico utilizado para detectar phishing. Determina si un correo electrónico debe ser entregado, o no, a su destinatario.

Malware: Término general utilizado para referirse a programas que contienen código dañino (Malicius software) ya sean virus, troyanos, gusanos o cualquier otra amenaza que afecta a la seguridad, disponibilidad e integridad de los sistemas informáticos. El código dañino se infiltra y daña un ordenador sin el conocimiento de la persona que lo utiliza, con finalidades muy diversas.

Ransomware (Ransom): Malware especialmente peligroso que impide el acceso a los ficheros de datos del personal, cifrándolos y pidiendo un rescate a cambio de una contraseña de recuperación.

Gusanos: Malware que tiene la propiedad de duplicarse a sí mismo sin la intervención de la persona usuaria.

Spyware: Malware diseñado para la recopilación de información acerca de los usuarios, equipos o hábitos de navegación entre otros. Se adhiere al sistema operativo sin conciencia de ello, por lo que se ejecuta en segundo plano y supervisa la actividad del dispositivo.

Adware: Tipo de software malicioso cuya instalación hace que la computadora muestre o descargue publicidad de manera automática

Troyano: Malware que llega al ordenador de manera encubierta, aparentando ser inofensivo, se instala y realiza determinadas acciones que afectan a la confidencialidad de la persona usuaria.

Virus: Programa que se introduce en los ordenadores y sistemas informáticos de formas muy diversas, produciendo efectos molestos, nocivos e incluso destructivos e irreparables.

Rootkits: Programa diseñado para ocultar objetos como procesos, archivos o entradas del Registro de Windows (incluyendo los suyos propios). Este tipo de software es utilizado para esconder evidencias y utilidades en sistemas previamente comprometidos.

5 REFERENCIAS

Para la aplicación de la presente norma se han tenido en cuenta otras normas, guías e instrucciones, que pueden sufrir actualización o modificación, y serán estas últimas las aplicables sin necesidad de modificar la actual norma.

- ISO/ IEC 27001:2022:
    - 8.7 Controles contra el código malicioso